

05-SUSPICIOUS-NETWORK-TOOL-EXECUTION

Suspicious Network Tool Execution Detection (C2 / Download)

Detection Scenario

This lab documents the detection of suspicious network utility execution on a Linux endpoint using kernel-level telemetry (auditd) ingested into Splunk Enterprise. The scenario simulates an post-compromise environment where an attacker, after achieving initial access and elevating privileges, utilizes native network downloaders (curl or wget) to communicate with external infrastructure, fetch secondary payloads, or perform staging actions.

Objective

Identify the execution of network-related binaries, reconstruct the full command string including external IP/domain arguments, and correlate this activity with the previous attacker actions to establish a complete chronological incident timeline.

Environment

- **Victim Server:** Ubuntu Server (with process auditing enabled)
- **SIEM Platform:** Splunk Enterprise
- **Auditing Daemon:** auditd (EXECVE logging rules active)
- **Log Shipper:** Splunk Universal Forwarder

Attack Simulation

Install Audit

To validate the visibility of outbound network artifacts at the process execution level, the following commands were manually executed from the compromised shell on the victim endpoint, simulating a remote staging download or a Command and Control beaconing check:

```
curl http://example.com
wget http://example.com
```

Data Source

Log File	/var/log/audit/audit.log
Index	Main
Sourcetype	Linux_audit

Detection Logic & SPL Queries

1. Dedicated Network Tool Detection (Filtro Táctico de Threat Hunting)

Query utilizada en el SOC para aislar inmediatamente cualquier ejecución que invoque de forma directa los comandos de red bajo monitoreo:

```
index=main sourcetype=linux_audit type=EXECVE ("curl" OR "wget")
```

2. Argument Reconstruction & Parsing (Visibilidad Completa del Destino Externo)

Query avanzada que organiza de forma tabular los argumentos secuenciales del sistema (a0 al a3), permitiendo al analista SOC identificar de manera inequívoca la URL, IP o dominio destino al que el atacante intentaba conectarse:

```
index=main sourcetype=linux_audit type=EXECVE ("curl" OR "wget")
| table _time host a0 a1 a2 a3
| rename a0 as "Executed Binary", a1 as "Argument 1", a2 as "Target URL/Domain", a3
as "Additional Flags"
```

3. Basic SOC Correlation Search (Correlación Cruzada Multiclase - Nivel Completo)

Query de alto valor que unifica múltiples sourcetypes (Ubuntu-Victima y linux_audit) para construir la línea de tiempo unificada del incidente: desde la autenticación del atacante, pasando por el uso de sudo, hasta la descarga del binario malicioso:

```
index=main (sourcetype="Ubuntu-Victima" OR sourcetype="linux_audit") ("Accepted
password" OR "sudo" OR "curl" OR "wget") | table _time host sourcetype _raw | sort
+ _time
```

Analysis

The security analysis verified that auditing system calls via type=EXECVE provides definitive advantage over standard application monitoring. The generated telemetry successfully captured not only the invocation of curl and wget but also resolved their execution arguments in plaintext (a2="http://example.com"). When performing triage and correlation, filtering out non-malicious standard processes (such as routine update scripts or grep checks) allows analysts to isolate automated download loops. The chronological concentration of these network calls immediately after an "Accepted password" or "session opened" event for sudo constitutes highly reliable indicators of post-exploitation activity.

Findings

- **Malicious Network Downloader Detection:** Direct logs confirming the use of standard binaries for non-administrative outbound communication.
- **Full URL/Domain Exposure:** Explicit visibility into external connection strings through auditd argument mapping fields (a1, a2).
- **Chronological Correlation:** Validated execution flow chaining matching initial access (SSH), privilege escalation (Sudo), and execution (Network Tool Download).
- **Defensive Evasion Resilience:** Telemetry remained persistent even if the attacker attempted to clear historical standard shell files (like .bash_history), since logs were recorded directly by the Linux kernel.

MITRE ATT&CK Mapping

- **Tactic:** Command and Control / Execution
- **Technique:** T1105 — Ingress Tool Transfer
- **Technique:** T1059 — Command and Scripting Interpreter

Impact

Unchecked execution of native utilities allows an adversary to drop secondary staging implants, establish persistent web shells, upgrade to fully functional Command and Control (C2) interactive channels, or perform covert data exfiltration of internal system files.

Classification

True Positive (Controlled laboratory activity representing real post-exploitation behavior).

Recommendations

1. Implement absolute Application Allowlisting policies (e.g., AppArmor, SELinux) to deny execution of network tools like curl, wget, nc, or socat by standard or non-whitelisted service users.
2. Restrict outbound egress firewall rules on production servers, allowing connections only to pre-approved repository domains.
3. Build behavioral correlations in Splunk Enterprise to generate high-priority alerts whenever an interactive user shell invokes a network downloader following a sudo elevation.
4. Establish continuous threat hunting tasks monitoring anomalies in process argument lengths or unusual target top-level domains (TLDs).